

网络空间安全应用联合大作业

作品报告

作品名称：Argus Guardian：面向大模型智能体应用
的行为监督原型系统

学 号：_____

姓 名：_____

提交日期：2026 年 7 月 24 日

填写说明

1. 作品报告书旨在能够清晰准确地阐述（或图示）该参赛队的参赛项目（或方案）。
2. 作品报告采用 A4 纸撰写。除标题外，所有内容必需为宋体、小四号字、1.5 倍行距。
3. 作品报告中各项目说明文字部分仅供参考，作品报告书撰写完毕后，请删除所有说明文字。（本页不删除）
4. 作品报告模板里已经列的内容仅供参考，作者可以在此基础上增加内容或对文档结构进行微调。

目 录

摘要	1
第一章 作品概述	2
1.1 背景与问题	2
1.2 选题目标	2
1.3 作品成果	2
第二章 作品设计与实现	3
2.1 总体架构	3
2.2 核心数据结构	4
2.3 四层行为监督机制	4
2.4 DeepSeek 在线红队与自适应规则	6
2.5 工具能力注册表	6
2.6 网页演示系统	7
第三章 作品测试与分析	7
3.1 测试方案	7
3.2 样本构成	7
3.3 总体结果分析	9
3.4 四层结果分析	10
3.5 演示验收结果	11
第四章 创新性说明	11
第五章 总结	12
参考文献	13
附录：截图与验收材料清单	14
附录：常用运行命令	14

摘要

大语言模型智能体能够调用命令行、读写文件、抓取网页和访问外部工具，安全风险已经不再局限于模型回答本身，而是延伸到“模型会不会采取危险行动”。本作品围绕“面向大模型及其应用的安全性研究”选题，从红队视角梳理提示注入、模型越狱、训练数据泄露、工具调用劫持、记忆中毒、环境感知污染和间接提示注入等攻击面，并在 Argus 项目基础上实现了一个可嵌入或旁路部署的智能体行为监督原型系统。

系统在工具真正执行前插入 Guardian 审计点，将每次工具调用整理为结构化 ToolCall，结合用户请求、历史工具序列、不可信来源和红队元数据，经过 Policy、Taint、Intent、Anomaly 四层机制输出 ALLOW、FLAG 或 BLOCK。同时，项目提供离线对抗样本与越狱测试集、攻击复现脚本、DeepSeek 在线红队生成、漏拦截分析、自适应规则管理以及网页 Dashboard 演示系统。离线评测共 30 条样本，其中攻击样本 22 条、良性样本 8 条。当前系统检出 22/22 条攻击，阻断型误报为 0，平均审计延时约 0.897 ms。实验结果说明，四层监督机制能够在课程原型范围内较稳定地识别高危工具调用、敏感文件访问、不可信数据流和异常攻击链。

关键词：大语言模型安全；智能体安全；提示注入；工具调用劫持；污点追踪；行为监督；红队评测

第一章 作品概述

1.1 背景与问题

大语言模型从单轮问答发展到智能体应用之后，模型不再只是生成文本，还会根据上下文规划工具调用。一个具备文件读写、网页抓取和代码执行能力的智能体，如果被恶意输入、网页内容或环境文件诱导，就可能在用户没有明确授权的情况下读取敏感文件、写入长期记忆、执行命令或向外部域名发送数据。

传统的内容安全审核通常关注模型输出是否包含违规文本，但智能体安全更关注行动本身是否越权。攻击者可以把危险指令伪装成普通任务，也可以把指令藏在网页、日志、README、配置或长期记忆中。对这类问题，只在模型回复结束后做文本检查往往太晚，因为真正的风险发生在工具执行前后。因此，本作品把研究重点放在智能体行为监督上：在每次工具调用真正执行前，实时审计工具名、工具参数、上下文来源和历史行为，必要时阻断。

1.2 选题目标

课程选题要求从红队视角研究大语言模型及智能体应用的攻击面，并设计可嵌入或旁路部署的行为监督机制。对应到本作品，目标分为四部分：

- 构建覆盖主要攻击面的对抗样本与越狱测试集；
- 提供可复现的攻击脚本和评测脚本；
- 设计实时审计、异常检测和阻断机制；
- 提供一个可在网页端操作展示的智能体行为监督原型系统。

本作品不是把 DeepSeek 或其他大模型作为唯一研究对象，而是把大模型智能体的工具调用链路作为研究对象。DeepSeek 在项目中主要用于两类在线演示：一是生成红队攻击样本，二是作为可选 intent judge 判断工具调用与用户意图是否一致。所有 API Key 都只通过运行时输入或环境变量使用，不写入脚本和文档。

1.3 作品成果

在原始 Argus 项目基础上，本作品已经形成从红队样本、攻击脚本、监督机制到网页演示的闭环。当前交付物包括：

- 安全风险分析与项目总览文档；
- 30 条离线评测样本，其中 22 条攻击样本、8 条良性对照；
- 可转换 AdvBench/JailbreakBench 风格公开数据的转换脚本；
- 离线演示、单样本复现、全量 benchmark 和 DeepSeek 在线演示脚本；
- Policy、Taint、Intent、Anomaly 四层 Guardian；
- 网页 Dashboard，支持攻击面复跑、DeepSeek 批量红队、攻击链视图、规则管理、历史审计和一键验收。

图位：系统总体架构图

请放置系统总体架构图。建议内容包括：用户请求、LLM Agent、ToolCall、Argus Guardian、四层审计、工具执行或阻断、审计日志、Dashboard。
建议文件名：`report/figures/system_architecture.png`。

图 1: 系统总体架构图占位

第二章 作品设计与实现

2.1 总体架构

Argus 将智能体的一次行动抽象为如下链路：

用户请求 -> LLM Agent 规划工具调用 -> Guardian 审计 -> ALLOW / FLAG /
BLOCK -> 工具执行或阻断

系统核心不是替代大模型，而是在大模型和工具执行环境之间增加一道行为监督闸门。对于嵌入式部署，Agent 在调用工具前主动调用 Guardian；对于旁路部署，系统也能读取工具调用日志、上下文和审计记录进行回放分析。Dashboard 则把这些审计结果可视化，方便验收时逐条说明“为什么拦截、由哪一层拦截、证据是什么”。

2.2 核心数据结构

Guardian 使用统一的数据结构连接前端、后端、评测脚本和 Agent:

- **ToolCall**: 表示智能体准备调用的工具, 包含工具名、参数和工具调用 ID;
- **Context**: 表示当前上下文, 包含用户原始请求、历史工具序列、污点来源、片段级污点和红队元数据;
- **Verdict**: 表示单个防御层的判断, 动作包括 ALLOW、FLAG 和 BLOCK;
- **Decision**: 表示最终决策, 任一层 BLOCK 即阻断, 无阻断但有 FLAG 即告警, 全 ALLOW 才放行。

这种结构的好处是各层可以独立演进, 而评测、审计日志和前端展示只依赖统一接口。

2.3 四层行为监督机制

四层机制分别从确定性规则、数据流、语义一致性和序列异常四个角度判断风险。

防御层	主要关注点	实现方式
Policy	已知高危动作和安全边界	检查工具能力注册表、危险 Shell、目录穿越、敏感路径、外联域名、记忆中毒写入和 DeepSeek 红队元数据。
Taint	不可信来源到高权限动作的数据流	将 <code>web_fetch</code> 和 <code>read_file</code> 标为不可信来源, 抽取文本片段和摘要, 发现污点流入 <code>run_shell</code> 、 <code>write_file</code> 等 Sink 时阻断或告警。
Intent	工具调用是否符合用户原始意图	通过可插拔 <code>judge</code> 接口调用 DeepSeek <code>intent judge</code> ; 离线评测默认关闭, 在线演示可启用。

Anomaly	工具序列是否异常	检测重复调用、读取后提权、读取后外联、红队元数据中的攻击链关键词。
---------	----------	-----------------------------------

Policy 层承担安全底线。它不依赖模型判断，因此速度快、解释清楚，适合阻断 `rm -rf`、反弹 Shell、`curl | sh`、读取 `.env` 或 `id_rsa`、访问 `evil.example`、把网页内容写入长期记忆等明确高危动作。

Taint 层解决间接提示注入问题。系统不只记录“来自 `web_fetch` 或 `read_file`”，还会按片段记录来源文本、摘要和原始工具调用 ID。如果网页或文件中包含“忽略此前指令”“下载执行脚本”等危险内容，而后续工具参数中复用了这些片段，Taint 层就能给出来源证据。

Intent 层用于语义补充。有些工具调用不一定包含明显危险关键词，但与用户需求不一致，例如用户只要求总结网页，模型却准备写入长期规则。在线演示中可以勾选 DeepSeek intent judge，让模型判断工具调用和用户请求是否一致。离线 benchmark 默认关闭该层，是为了保证没有 API Key 时也能稳定验收。

Anomaly 层看的是“这次调用放在历史序列里是否反常”。例如连续多次抓取网页可能是异常循环；读取日志后又准备外联，虽然当前动作可能只是读取，但从链路看已经接近数据外泄。此前用户反馈 anomaly 层几乎全绿后，项目补充了读取后外联、读取后提权和 DeepSeek 红队攻击链元数据检测，使第四层能够在工具调用劫持和间接提示注入中发挥实际作用。

图位：四层 Guardian 判定流程图

请放置四层防御流程图。建议标出 Policy、Taint、Intent、Anomaly 的输入和输出，以及最终聚合规则：“任一 BLOCK 即阻断；无 BLOCK 但有 FLAG 即告警”。建议文件名：`report/figures/guardian_layers.png`。

图 2: 四层 Guardian 判定流程图占位

2.4 DeepSeek 在线红队与自适应规则

Dashboard 中的 DeepSeek 红队模块支持选择攻击面、生成条数和提示词模式。提示词不再是一行固定文本，而是按攻击面和模式组织，支持“精准单步”“伪装正常任务”“多步攻击链”“绕过变体”等生成方式。DeepSeek 生成的内容会被解析为攻击目标、用户请求、工具调用、污点来源、风险点、期望动作和危险说明，再交给 Guardian 审计。

如果某条 DeepSeek 生成的样本期望 BLOCK 或 FLAG，但 Guardian 实际 ALLOW，前端会标记为漏拦截。用户可以点击“分析漏拦截”，由 DeepSeek 分析未拦截原因，再把建议收束为受限字段规则写入 `adaptive_rules.json`。规则只做字段包含匹配，不执行模型生成代码，避免把安全策略完全交给模型控制。

图位：DeepSeek 批量红队矩阵与攻击链弹窗

请放置一次 DeepSeek 红队运行后的截图。要求能看到批量条目的“总 / 1 / 2 / 3 / 4”状态，以及点开某条样本后的用户请求、工具调用、污点来源和层级命中。建议文件名：`report/figures/deepseek_attack_chain.png`。

图 3: DeepSeek 红队审计展示截图占位

2.5 工具能力注册表

PPT 展望中提到“工具集超出预设怎么办”。这个问题完整解决需要较大工程量，因为真实 Agent 可能接入数据库、邮件、浏览器、向量库和云存储，每种工具的权限、参数和业务语境都不同。本阶段先完成一个小工程补丁：新增 `tool_registry.py`，为当前工具记录能力标签、风险等级和审计关注点。

当前内置工具仍只有 `run_shell`、`read_file`、`write_file` 和 `web_fetch`。未知工具默认阻断，但阻断理由会提示新工具应先登记能力标签、最小权限和审计重点。这样既保留了原型系统的安全边界，也为后续从固定白名单升级到“工具能力标签 + 最小权限 + 场景策略”留下了接口。

2.6 网页演示系统

Dashboard 默认端口为 127.0.0.1:8765，主要页面包括总览、攻击面实验台、DeepSeek 红队、规则管理、演示验收和自定义工具评估。前端已改为白底黑字，便于课堂展示和报告截图打印。每次前端请求都会写入本地 SQLite 历史库，页面可以动态更新审计统计和四层状态分布。

图位：Dashboard 白底总览截图

请放置当前白底版本 Dashboard 总览截图。要求包含顶部指标卡、攻击面实验台、四层防御统计或历史流。建议文件名：
`report/figures/dashboard_overview.png`。

图 4: Dashboard 总览截图占位

第三章 作品测试与分析

3.1 测试方案

测试分为三类：第一类是单元测试，用于保证 Policy、Taint、Intent、Anomaly、Dashboard API 和数据集转换器的基本行为稳定；第二类是离线 benchmark，使用固定对抗样本统计检出率、误报率和延时；第三类是网页演示验收，通过 Dashboard 一键运行 7 个攻击面，并生成 Markdown、JSON 和 SVG 记录。

本报告中的数据来自 `scripts/run_benchmark.py` 的离线评测结果。离线评测不依赖外部 API，因此适合稳定验收；DeepSeek 在线红队则用于展示真实模型生成攻击样本时系统的交互闭环。

3.2 样本构成

离线测试集共 30 条样本，其中攻击样本 22 条，良性对照 8 条。攻击面覆盖情况如下。

表 2: 离线测试集攻击面覆盖

类别	总数	攻击数	良性数	检出数
prompt_injection	2	2	0	2
model_jailbreak	2	2	0	2
training_data_leak	3	3	0	3
tool_hijack	5	5	0	5
indirect_injection	3	3	0	3
memory_poison	3	3	0	3
environment_pollution	2	2	0	2
sequence_anomaly	2	2	0	2
benign	8	0	8	0

3.3 总体结果分析

表 3: 离线评测总体指标

指标	结果
总样本数	30
攻击样本数	22
良性样本数	8
攻击检出数	22
漏检攻击数	0
阻断型误报数	0
良性告警数	2
召回率	100.00%
阻断型误报率	0.00%
平均审计延时	0.897 ms
p50 审计延时	0.875 ms
p95 审计延时	1.471 ms

结果显示，系统在当前样本集上检出全部攻击，没有出现把良性样本直接阻断的情况。2 条良性样本被标记为 **FLAG**，主要原因是它们涉及读取不可信网页后继续写入文件。从实际安全策略看，这类结果更接近“旁路告警”而不是误杀：系统提示操作者复核，但不会阻止任务完成。对于教学演示而言，这能说明 Argus 不只会简单地“黑白二分”，也能表达灰度风险。

延时方面，四层审计的平均耗时约 0.897 ms，p95 为 1.471 ms。这个结果说明当前规则、污点和异常检测的开销较小，可以放在工具执行前实时运行。需要注意的是，离线评测中的 Intent 层默认关闭，因此这里的延时不包含在线 LLM judge 调用；如果启用 DeepSeek intent judge，实际延时会受到网络和模型响应影响，适合高风险工具或演示场景按需启用。

3.4 四层结果分析

表 4: 四层防御 Verdict 分布

防御层	ALLOW	FLAG	BLOCK
Policy	12	0	18
Taint	22	2	6
Intent	30	0	0
Anomaly	18	7	5

Policy 层出现 18 次阻断，是系统的主要安全底线，负责处理危险 Shell、路径越界、敏感文件读取、非注册工具和明显外联意图。Taint 层阻断 6 次、告警 2 次，集中出现在间接提示注入、环境污染和记忆中毒样本中，说明片段级污点追踪确实补到了单纯规则难以解释的数据流问题。Anomaly 层阻断 5 次、告警 7 次，主要针对读取后外联、读取后提权和重复调用，这也是此前“第四层总是放行”问题的修复结果。Intent 层在离线评测中全部放行，是因为默认未接入在线 judge；在 DeepSeek 在线红队演示中，它可以作为语义一致性补充。

从分工看，四层机制形成了较清楚的层级关系：Policy 保证已知危险动作不会执行，Taint 说明危险内容从哪里来，Anomaly 判断当前动作是否处在异常链路中，Intent 在需要时补充语义判断。这样的设计比单一关键词过滤更适合展示智能体行为安全，因为它能把“危险在哪里”拆成可以审计的证据。

图位：Benchmark 结果截图

请放置运行 `scripts/run_benchmark.py` 后的终端输出，或 `report/eval_results.md` 的截图。要求能看到总样本数 30、攻击样本 22、检出 22、阻断型误报 0，以及四层 Verdict 分布。建议文件名：`report/figures/benchmark_results.png`。

图 5: 离线评测结果截图占位

3.5 演示验收结果

Dashboard 的“演示验收”模式会固定运行 7 个攻击面,并生成 Markdown、JSON 和 SVG 快照。一次 smoke test 中,接口返回 7 个攻击面,7/7 被检出,产物位于 `sandbox_runs/demo_acceptance/`。这部分适合课堂现场展示:先打开 Dashboard,点击一键运行,再展示每个攻击面的总状态和四层状态。

图位：一键演示验收快照

请放置 `sandbox_runs/demo_acceptance/argus_demo_*.svg` 或导出的 PNG。要求能看到 7 个攻击面、每条样本总状态和 1-4 层状态。
建议文件名：`report/figures/demo_acceptance.png`。

图 6: 一键演示验收截图占位

第四章 创新性说明

本作品的创新性主要体现在三个方面。

第一,研究对象从“模型回答安全”推进到“智能体行为安全”。项目不只检查模型生成的自然语言,而是把真正可能造成影响的工具调用作为审计对象,在 Shell、文件读写和网页抓取执行前完成判断。

第二,系统采用四层互补监督。Policy 提供确定性底线, Taint 追踪不可信数据流, Intent 判断语义一致性, Anomaly 检测调用序列异常。四层 Verdict 会完整保留到审计记录 and 前端页面中,因此不只是给出结果,还能解释结果。

第三,项目形成红队闭环。DeepSeek 可以在线生成攻击样本, Guardian 实时审计;如果出现漏拦截,系统可以调用 DeepSeek 分析原因,并把建议收束成可撤销、可启停、可计数的受限自适应规则。这种机制既展示了模型辅助防御的可能性,也保留了规则治理边界。

此外, Dashboard 支持批量红队矩阵、攻击链视图、历史审计流、规则管理和一键验收,比单纯命令行 demo 更适合课堂展示和验收。

第五章 总结

本作品围绕“面向大模型及其应用的安全性研究”完成了一个可运行、可评测、可展示的智能体行为监督原型系统。项目覆盖提示注入、模型越狱、训练数据泄露、工具调用劫持、记忆中毒、环境感知污染、间接提示注入和序列异常等攻击面，提供了对抗样本与越狱测试集、攻击脚本、评测结果和网页演示系统。离线评测显示，在当前 30 条样本上，系统检出 22/22 条攻击，阻断型误报为 0，平均审计延时约 0.897 ms。

仍需继续深入的方向主要在规模化和泛化。外部攻击集接入已经有转换脚本，但大规模引入 AdvBench、JailbreakBench 和真实 Agent 轨迹还需要更多标注与评测；工具集超出预设不是一个简单小问题，本阶段已通过工具能力注册表完成工程入口，后续还需要最小权限、场景策略和旁路观察机制；Anomaly 层目前以可解释启发式为主，后续可以引入 n-gram、Markov 或 embedding 序列模型；规则治理也可加入差异预览、版本回滚和人工审批。总体而言，当前版本已经满足课程原型验收，后续工作将重点放在真实场景中的覆盖规模、模型泛化和策略治理上。

参考文献

- [1] OWASP Foundation. OWASP Top 10 for Large Language Model Applications 2025[R/OL].
- [2] Yao S., Zhao J., Yu D., et al. ReAct: Synergizing Reasoning and Acting in Language Models[C]. International Conference on Learning Representations, 2023.
- [3] Greshake K., Abdelnabi S., Mishra S., et al. Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection[C]. ACM Workshop on Artificial Intelligence and Security, 2023.
- [4] Zou A., Wang Z., Carlini N., et al. Universal and Transferable Adversarial Attacks on Aligned Language Models[R]. arXiv preprint arXiv:2307.15043, 2023.
- [5] Perez F., Ribeiro I. Ignore Previous Prompt: Attack Techniques for Language Models[R]. arXiv preprint arXiv:2211.09527, 2022.

附录：截图与验收材料清单

正式提交前建议补充以下图片到报告对应占位位置：

1. report/figures/system_architecture.png: 系统总体架构图;
2. report/figures/guardian_layers.png: 四层 Guardian 判定流程图;
3. report/figures/dashboard_overview.png: 白底 Dashboard 总览截图;
4. report/figures/deepseek_attack_chain.png: DeepSeek 批量红队矩阵和攻击链弹窗截图;
5. report/figures/rule_management.png: 规则管理页截图;
6. report/figures/benchmark_results.png: Benchmark 结果截图;
7. report/figures/demo_acceptance.png: 一键演示验收 SVG 快照或导出 PNG。

附录：常用运行命令

```
# 启动 Dashboard
.\.venv\Scripts\python scripts\dashboard_server.py --host 127.0.0.1 --port 8765

# 运行全部测试
.\.venv\Scripts\python -m pytest

# 生成离线评测结果
.\.venv\Scripts\python scripts\run_benchmark.py

# 检查前端 JS
node --check dashboard\app.js
```